

ScopeMate Security

Authentication

Use Clerk.

Homeowners can only access their own projects.

Contractors can only access invited projects.

Implement role-based access.

Database Security

Use Supabase Row Level Security.

Never trust client-side permissions.

Validate ownership server-side.

Share Links

Use secure random tokens.

Good:

/share/H7xK9qLm4T

Bad:

/project/123

Allow:

- Disable link
 - Regenerate link
 - Expire link
-

API Security

All AI requests server-side.

Never expose:

- OpenAI keys
- Supabase service role keys

Use:

- Input validation
 - Rate limiting
 - Request logging
-

AI Safety

AI must:

- Separate facts from assumptions
- Mark uncertain items
- Preserve user edits
- Avoid hallucinating dimensions
- Avoid hallucinating permit requirements

Use:

"Contractor must verify"

when uncertain.

Privacy

Avoid collecting:

- Full addresses
- Financial information
- Sensitive personal information

Prefer:

- City
- ZIP code

Allow users to:

- Delete projects
- Delete photos
- Delete account

Photo Handling

Photos may be processed by AI.

Display notice:

"AI-generated measurements and observations are estimates only and must be verified by a contractor."

Disclaimers

ScopeMate is a planning tool.

It does not provide:

- Engineering advice
- Architectural advice
- Permit advice
- Final construction pricing

Contractors remain responsible for final scope verification and pricing.